Design and apply context-aware access controls based on user identity, device posture, location, and application risk

**COLLEGE NAME :** Shri Nehru Maha Vidhyalaya College of Arts & Science.

**TEAM ID:** SWTID-2026-1943

**Team Leader :** PRIYA BHANDARI S

**Email :** priyaa10052005@gmail.com

**Team Member:** SHREYA PRAKASH

**Email :** 23bcashreyaprakash@gmail.com

**Team Member:** UDHAYA MOORTHI R

**Email :** udhayamoorthi2006@gmail.com

**Team Member:** KAJENDRAN K

**Email :**kajakaja7812@gmail.com

## Project Title

# Design and apply context-aware access controls based on user identity, device posture, location, and application risk

## Overview of the project

- Modern organizations face increasing cybersecurity threats due to remote work, cloud applications, and diverse devices accessing enterprise systems. Traditional security models that rely only on usernames and passwords are no longer sufficient.
- This project focuses on designing and implementing **context-aware access controls**, where access decisions are made dynamically based on multiple contextual factors such as **user identity, device posture, location, and application risk level**.
- The goal of this project is to build a **smart access control framework** that evaluates the context of each access request before granting or denying permission.
- The proposed system uses **identity-based authentication**, device security checks, geographic location verification, and application sensitivity levels to determine the appropriate level of access.
- For example, a trusted employee accessing a low-risk application from a company laptop inside the corporate network may be granted seamless access, while the same request from an unknown device or unusual location may require **multi-factor authentication (MFA)** or be blocked.
- This project follows the principles of **Zero Trust Security**, where no user or device is automatically trusted, even if they are inside the network. Every access attempt is verified using contextual data to reduce the risk of unauthorized access, data breaches, and insider threats.

## Abstract


- With the rapid growth of cloud services, mobile devices, and remote work environments, traditional access control mechanisms based solely on usernames and passwords are no longer sufficient to ensure organizational security.
- This project focuses on designing and implementing a **context-aware access control system** that dynamically evaluates multiple contextual factors before granting access to resources.
- The proposed system considers parameters such as **user identity, device posture, geographic location, and application risk level** to make intelligent and secure access decisions.
- Overall, the implementation of context-aware access controls enhances organizational security by enabling **dynamic, intelligent, and risk-based access management**, ensuring that the right users gain access to the right resources under the right conditions.

## Use case Scenarios

1. **Use Case: Trusted Employee Access from Secure Device**

   Employees working from home or remote locations access company resources through Zscaler. The user authenticates using Azure AD with Single Sign-On (SSO) and Multi-Factor Authentication (MFA).

**Output:**
Access Granted without additional authentication.

2. **Use Case: Employee Access from Unrecognized Device**
   An employee attempts to log in to the company portal using a **personal device** that is not registered with the organization.

**Output:**
System requires **Multi-Factor Authentication (MFA)** before granting access.

3. **Use Case: Login Attempt from Suspicious Location**
   A user tries to access the organization's system from a different country where the employee normally does not operate.

**Output:**
Access temporarily **restricted** and additional verification required (OTP or security confirmation).

4. **Use Case: Access to High-Risk Application**
   An employee tries to access a **high-risk application**, such as the company's **financial management system or sensitive database**.

**Output:**
System enforces Multi-Factor Authentication and role verification before granting access.

5. **Use Case: Unauthorized User Attempt**
   An unknown user tries to access a secure application using **invalid credentials**.

**Output:**
Access Denied and **security alert generated for administrators**.

**TITLE:**

OWASP TOP 10

**OVERVIEW:**

The **OWASP Top 10** is a standard awareness document published by the **Open Web Application Security Project (OWASP)** that identifies the most critical security risks to web applications. It is designed to help developers, security professionals, and organizations understand common vulnerabilities that attackers often exploit. The OWASP Top 10 highlights major risks such as **Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, and Server-Side Request Forgery (SSRF)**. These vulnerabilities can allow attackers to gain **unauthorized access, steal sensitive data, modify information, or even take full control of a system**. For example, **Injection attacks** occur when malicious code is inserted into a program, while **Broken Access Control** allows users to access resources they are not authorized to use. Similarly, **Cryptographic Failures** happen when sensitive data such as passwords or credit card information is not properly encrypted. The OWASP Top 10 serves as a guideline for improving application security by encouraging organizations to adopt **secure coding practices, proper configuration, regular updates, and continuous monitoring**. By understanding and addressing these risks, developers can build more **secure and reliable web applications** and reduce the chances of cyberattacks.

| Rank | Vulnerability |
|---|---|
| 1 | Broken Access Control |
| 2 | Security Misconfiguration |
| 3 | Injection |
| 4 | Insecure Design |
| 5 | Cryptographic Failures |
| 6 | Mishandling of Exceptional conditions |
| 7 | Software or Data Integrity Failures |
| 8 | Software Supply Chain Failures |
| 9 | Security Logging and Monitoring Failures |
| 10 | Authentication Failures |

| S.NO | Vulnerability | CWE/CVE NO |
|---|---|---|
| 1. | Improper Limitation of a Pathname to a Restricted directory (‘Path Traversal’) | CWE-22 |
| 2. | J2EE Misconfiguration: Data Transmission Without Encryption. | CWE-5 |
| 3. | Improper Input Validation | CWE-20 |
| 4. | External Control of File Name or Path | CWE-73 |
| 5. | Weak Encoding for Password | CWE-261 |
| 6. | Failure to Handle Missing Parameter | CWE-234 |
| 7. | Missing Support for Integrity Check | CWE-353 |
| 8. | Unimplemented or Unsupported Feature in UI | CWE-447 |
| 9. | Improper Output Neutralization for Logs | CWE-117 |
| 10. | Improper Authentication | CWE-287 |

# REPORT:

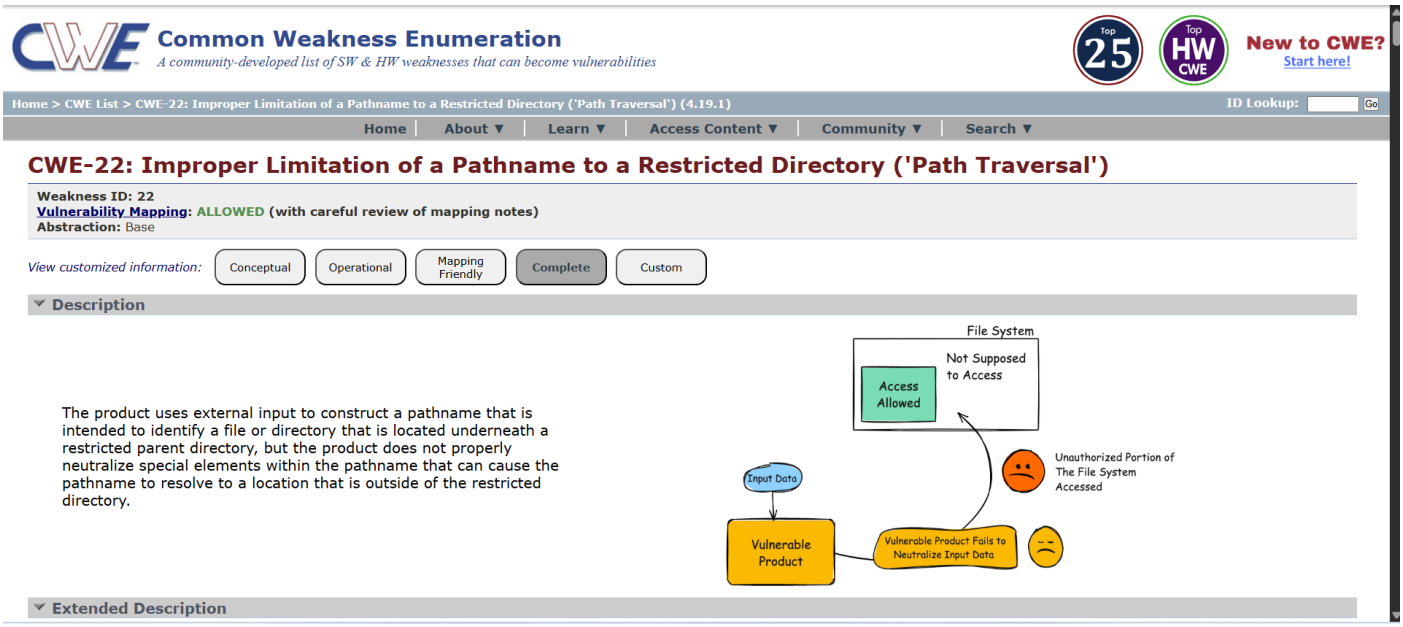
**1.Vulnerability Name :** Improper Limitation of a Pathname to a Restricted directory (‘Path Traversal’)

**CWE NO :** CWE-22

**OWASP Category :** Broken Access Control

**Description:** Path Traversal is a security vulnerability that occurs when a web application does not properly control user input used in file paths. This allows attackers to access files and folders outside the restricted directory by using special characters like ../ to move up the directory structure. For example, an attacker might try to access sensitive files such as system configuration files that should not be available to users. This can lead to unauthorized access to important data and system files. To prevent path traversal attacks, developers should validate user input, restrict file access, and use secure coding practices.

**Business Impact :** Path Traversal attacks can cause serious problems for organizations. Attackers may gain access to sensitive business data, customer information, or internal system files, which can lead to data breaches, financial loss, and damage to the organization’s reputation. It can also result in legal penalties, loss of customer trust, and operational disruptions if important systems or data are compromised.



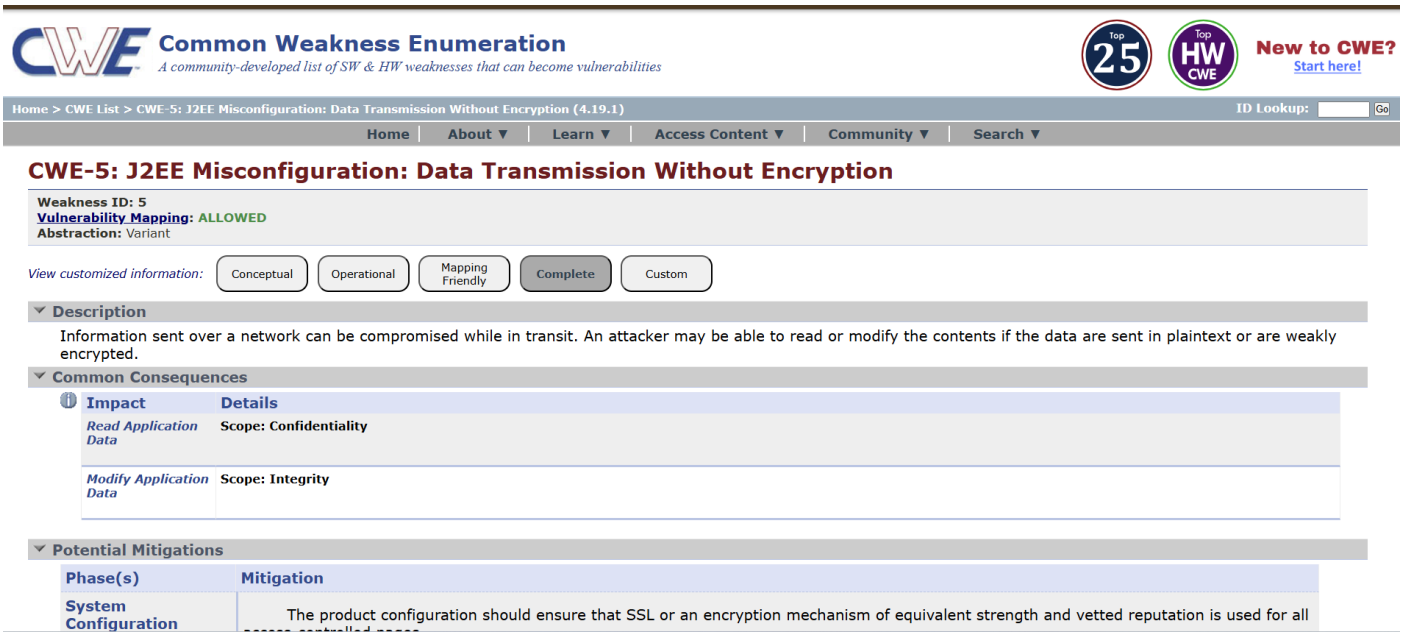

**2) Vulnerability Name :** J2EE Misconfiguration: Data Transmission Without Encryption.

**CWE NO :**CWE-5

**OWASP Category:** Security Misconfiguration

**Description**: J2EE Misconfiguration: Data Transmission Without Encryption (CWE-5) occurs when a J2EE (Java 2 Platform, Enterprise Edition) application transmits sensitive data over a network without using encryption. This usually happens when the application uses HTTP instead of HTTPS or does not implement secure protocols like SSL/TLS. As a result, information such as usernames, passwords, personal data, or financial details can be intercepted by attackers while it is being transmitted between the client and the server.

**Business Impact :** If sensitive data is transmitted without encryption, attackers can capture confidential information, leading to data breaches, unauthorized account access, and identity theft. For organizations, this can result in financial losses, legal and regulatory penalties, reputational damage, and loss of customer trust. It may also expose internal systems and increase the risk of further cyberattacks.



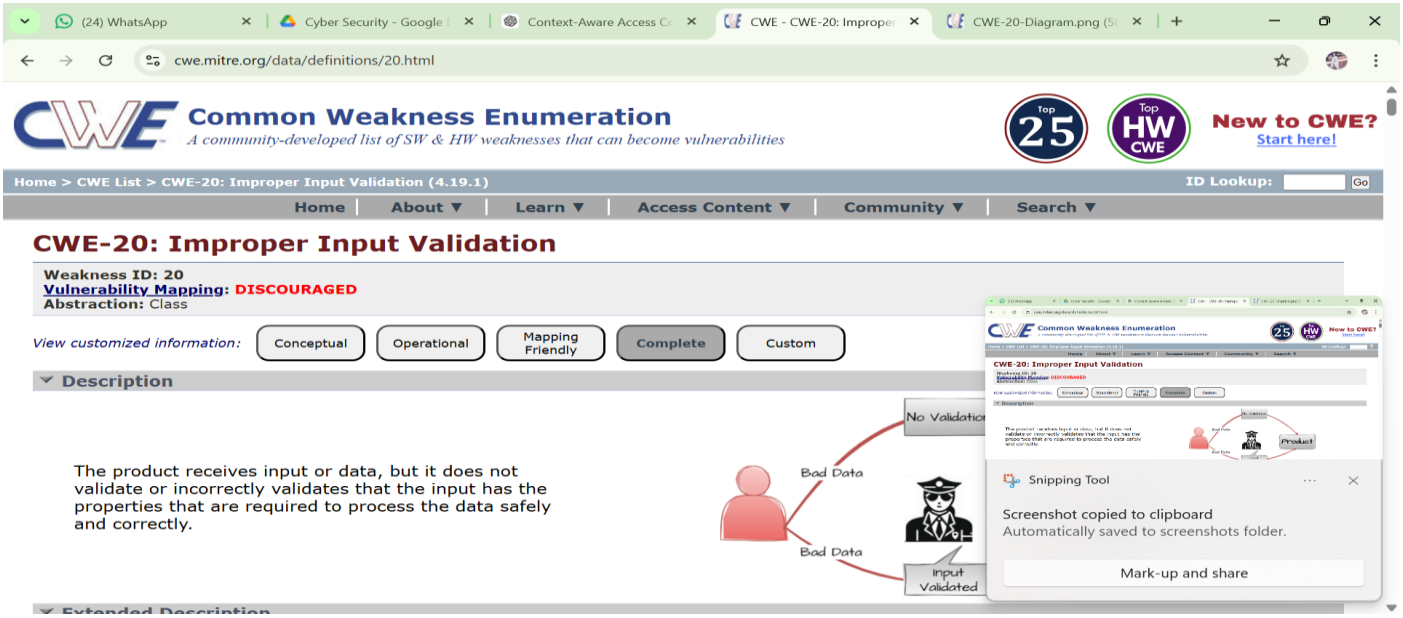

**3) Vulnerability Name:** Improper Input Validation

**CWE NO:** CWE-20

**OWASP Category**: Injection

**Description**: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

**Business Impact :** If attackers exploit input validation vulnerabilities, they may gain unauthorized access to sensitive data such as customer information, financial records, or confidential business data. This can lead to major security incidents and loss of trust.



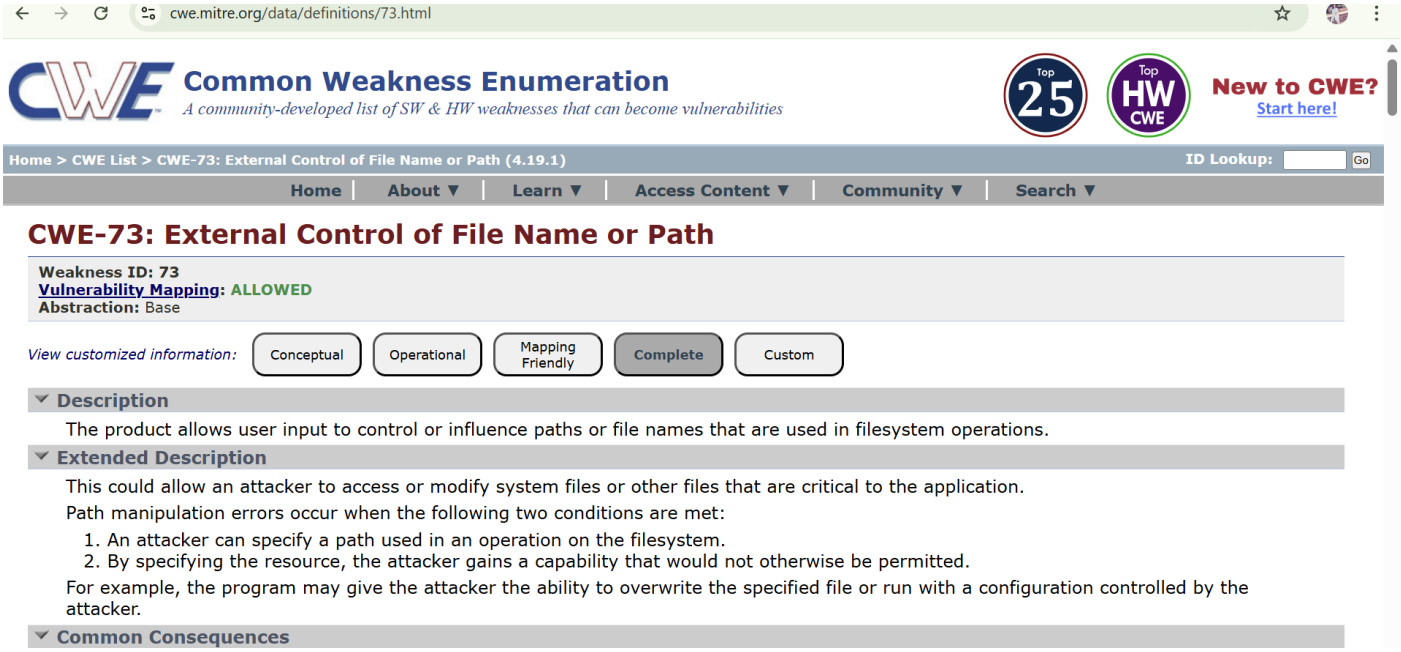
**4) Vulnerability Name :** External Control of File Name or Path

**CWE NO :** CWE-73

**OWASP Category:** Insecure Design

**Description:** The product allows user input to control or influence paths or file names that are used in filesystem operations.

**Business Impact :** Attackers may use techniques such as **path traversal** to access confidential files like configuration files, system logs, or databases. This can expose sensitive business or customer information.




**5) Vulnerability Name :** Weak Encoding for Password

**CWE NO :** CWE-261

**OWASP Category:** Cryptographic Failures

**Description:** Obscuring a password with a trivial encoding does not protect the password.

**Business Impact :** If passwords are weakly encoded, attackers can easily decode or crack them. This allows unauthorized users to gain access to employee or customer accounts.

Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-261: Weak Encoding for Password (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

## CWE-261: Weak Encoding for Password

**Weakness ID: 261**
**Vulnerability Mapping: ALLOWED**
**Abstraction:** Base

*View customized information:* Conceptual | Operational | Mapping Friendly | Complete | Custom

**Description**

Obscuring a password with a trivial encoding does not protect the password.

**Extended Description**

Password management issues occur when a password is stored in plaintext in an application's properties or configuration file. A programmer can attempt to remedy the password management problem by obscuring the password with an encoding function, such as base 64 encoding, but this effort does not adequately protect the password.

**Common Consequences**

| Impact | Details |
|---|---|
| *Gain Privileges or* | **Scope: Access Control** |

**6) Vulnerability Name :** Failure to Handle Missing Parameter

**CWE NO :** CWE-234

**OWASP Category:** Mishandling of Exceptional conditions

**Description:** If too few arguments are sent to a function, the function will still pop the expected number of arguments from the stack. Potentially, a variable number of arguments could be exhausted in a function as well.

**Business Impact :** If the system cannot handle missing parameters correctly, it may cause application crashes or unexpected behavior. This can interrupt business operations and reduce system reliability.

Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities

New to CWE? Start here!

Home > CWE List > CWE-234: Failure to Handle Missing Parameter (4.19.1)

ID Lookup: Go

Home | About ▼ | Learn ▼ | Access Content ▼ | Community ▼ | Search ▼

## CWE-234: Failure to Handle Missing Parameter

**Weakness ID: 234**
**Vulnerability Mapping: DISCOURAGED**
**Abstraction:** Variant

*View customized information:* Conceptual | Operational | Mapping Friendly | Complete | Custom

**Description**

If too few arguments are sent to a function, the function will still pop the expected number of arguments from the stack. Potentially, a variable number of arguments could be exhausted in a function as well.

**Common Consequences**

| Impact | Details |
|---|---|
| *Execute Unauthorized Code or Commands; Gain Privileges or Assume Identity* | **Scope: Integrity, Confidentiality, Availability, Access Control**<br>There is the potential for arbitrary code execution with privileges of the vulnerable program if function parameter list is exhausted. |

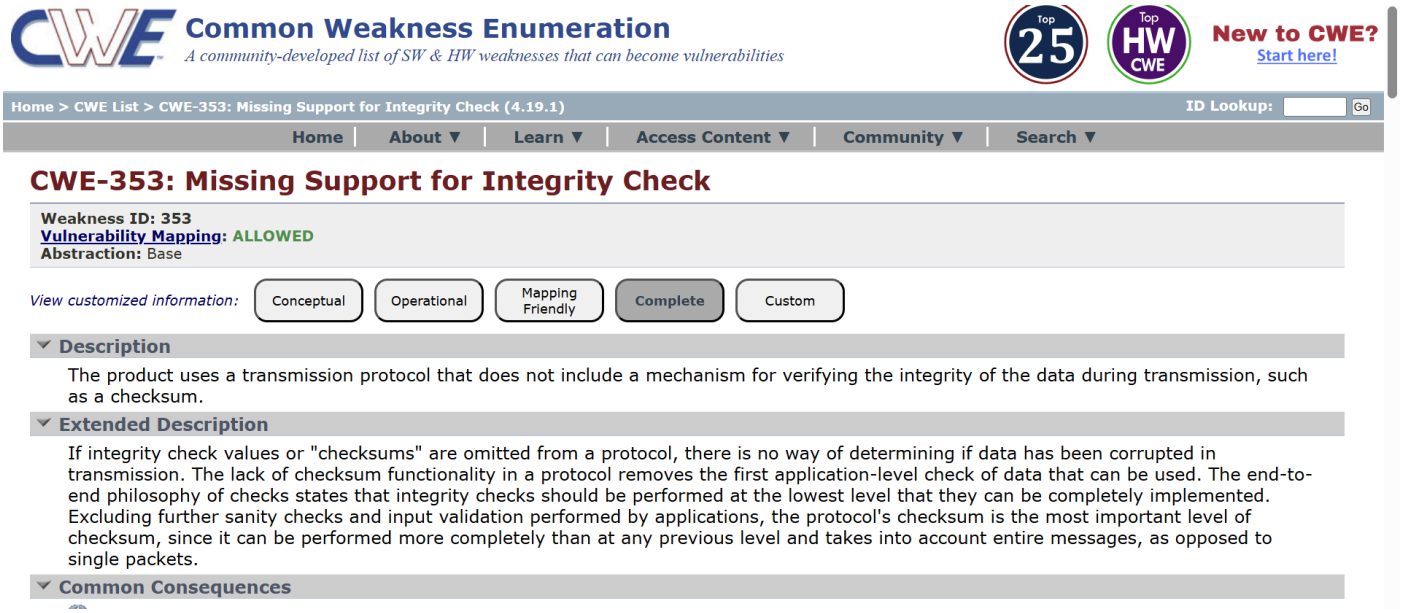
**7) Vulnerability Name :** Missing Support for Integrity Check

**CWE NO :** CWE-353

**OWASP Category**: Software or Data Integrity Failures

**Description:** The product uses a transmission protocol that does not include a mechanism for verifying the integrity of the data during transmission, such as a checksum.

**Business Impact :** Without integrity checks, attackers or unauthorized users may modify critical data such as financial records, transaction details, or system files without detection. This can compromise the accuracy and reliability of business information.



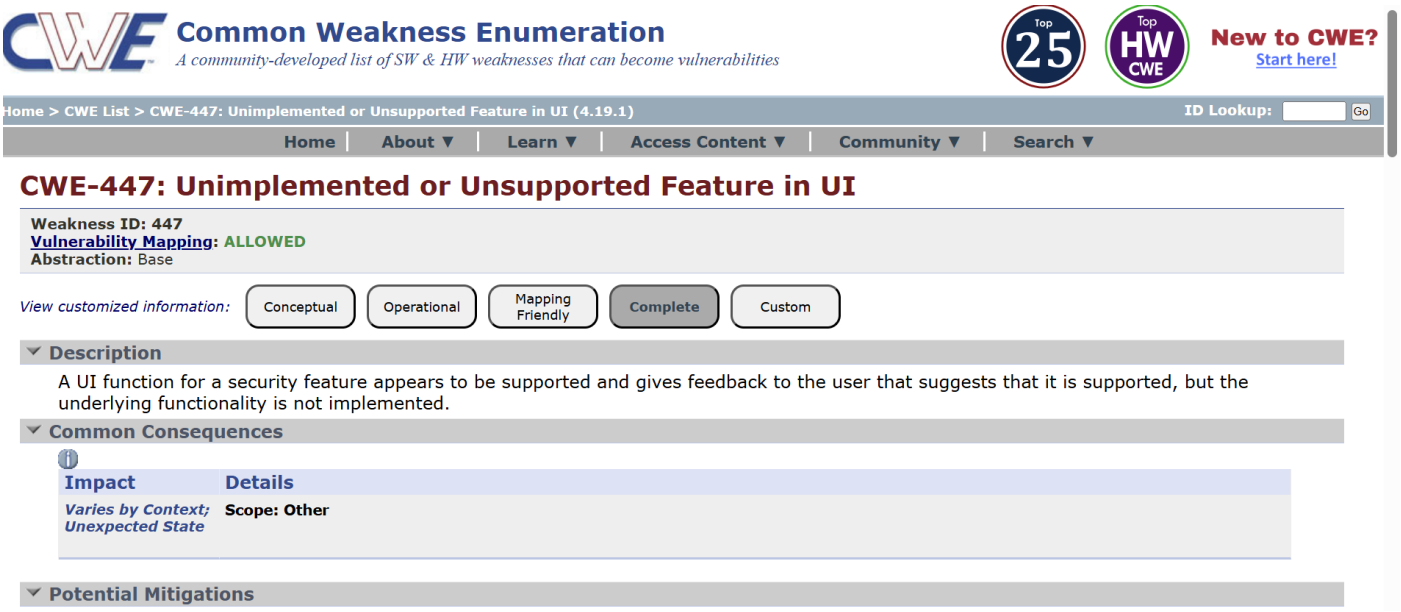

**8) Vulnerability Name :** Unimplemented or Unsupported Feature in UI

**CWE NO :** CWE-447

**OWASP Category**: Software Supply Chain Failures

**Description**: A UI function for a security feature appears to be supported and gives feedback to the user that suggests that it is supported, but the underlying functionality is not implemented.

**Business Impact** :Users may become frustrated if they see features in the interface that do not work properly. This can reduce customer satisfaction and affect the overall user experience.



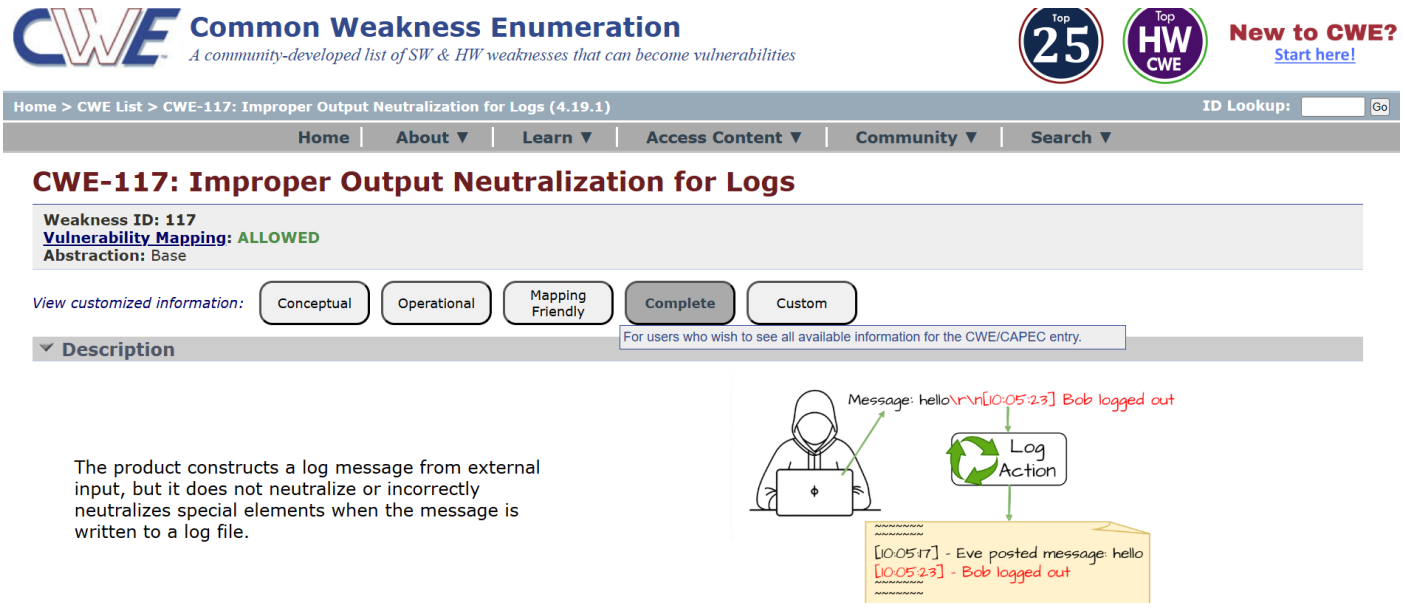

**9) Vulnerability Name :** Improper Output Neutralization for Logs

**CWE NO**: CWE-117

**OWASP Category:** Security Logging and Monitoring Failures

**Description:** The product constructs a log message from external input, but it does not neutralize or incorrectly neutralizes special elements when the message is written to a log file.

**Business Impact :** Attackers may insert malicious characters or commands into log entries, allowing them to modify or hide their activities. This can make it difficult for administrators to detect security incidents.



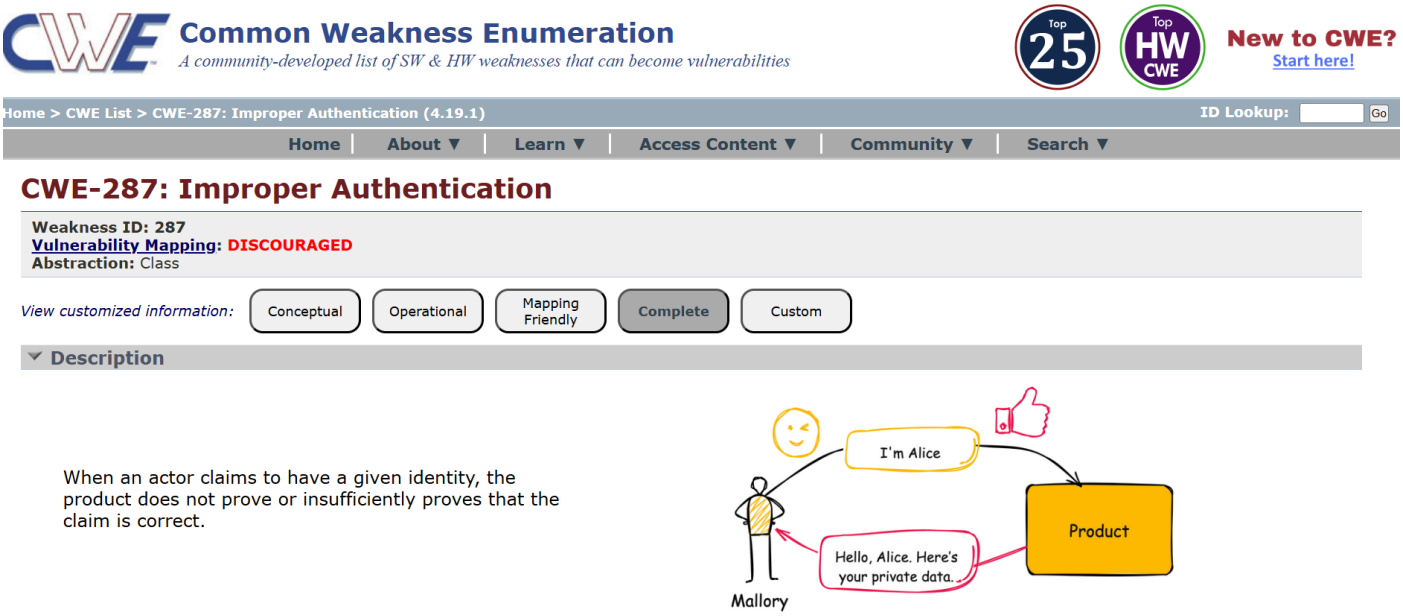

**10) Vulnerability Name :** Improper Authentication

**CWE NO :** CWE-287

**OWASP Category:** Authentication Failures

**Description:** When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.

**Business Impact :** Attackers may exploit weak authentication mechanisms to access restricted systems or accounts without proper credentials. This can lead to unauthorized actions within the system



**TITLE:** NESSUS SCAN

## OVERVIEW:

**Nessus** is a widely used **vulnerability scanning tool** developed by **Tenable**. It is used by security professionals to identify **security weaknesses, misconfigurations, and vulnerabilities** in computers, networks, servers, and applications. Nessus works by scanning systems and comparing them with a large database of known vulnerabilities to detect potential security risks.

During a **Nessus scan**, the tool checks for issues such as **outdated software, missing security patches, weak configurations, open ports, and known security vulnerabilities**. It uses thousands of plugins to test systems and identify problems that attackers could exploit. After the scan is completed, Nessus generates a **detailed report** that lists the vulnerabilities found, their severity levels (Critical, High, Medium, Low), and recommendations for fixing them.

**Importance of Nessus Scan:**
Nessus scanning helps organizations **improve their security posture** by identifying risks before attackers can exploit them. It allows security teams to **prioritize vulnerabilities, apply patches, and strengthen system security**. Regular Nessus scans are an important part of **vulnerability management and cybersecurity practices**.

| S.NO | Vulnerability Name | Severity | Plugins |
|---|---|---|---|
| 1. | Nessus SYN Scanner | INFO | 11219 |
| 2. | Service Detection | INFO | 22964 |
| 3. | Traceroute information | INFO | 10287 |
| 4. | TCP/IP Timestamps Supported | INFO | 25220 |
| 5. | Device type | INFO | 54615 |
| 6. | Shor's Harvest Now Decrypt Later | CRITICAL | 298387 |
| 7. | Canonical Ubuntu Linux SEoL (14.04.x) | CRITICAL | 201408 |
| 8. | Backported Security Patch Detection (WWW) | INFO | 39521 |
| 9. | SSH Protocol Versions Supported | INFO | 10881 |
| 10. | Backported Security Patch Detection (SSH | INFO | 39520 |

## REPORT:

**1)Vulnerability:** Nessus SYN Scanner

**Severity:** INFO

**Plugin:** 11219

**Description:** The Nessus SYN Scanner plugin performs a TCP SYN scan to identify open TCP ports on a target host.
It sends a SYN packet to a port and analyzes the response:

- SYN/ACK → Port is open
- RST → Port is closed
- No response / filtered → Port may be filtered by a firewall

This method is commonly called a "half-open scan" because the TCP connection is not fully established. Nessus uses it to quickly detect running services and exposed ports on the target system.

**Solution:** Since this plugin is informational, it mainly reports network discovery results, but reviewing exposed services is still important for security.

**Bussiness Impact:** This is not a vulnerability by itself, but it indicates that:

- The scanner successfully identified open ports and services.
- Unnecessary or exposed services may increase the attack surface.
- Attackers could use similar scanning techniques to discover services and potential entry points.
- If critical services are exposed (e.g., SSH, FTP, databases), they could be targeted for exploitation

**2)Vulnerability:** Service Detection

**Severity:** INFO

**Plugin:** 22964

**Description**: This plugin identifies services running on open ports of the target system. Nessus analyzes responses from the ports to determine the type of service and sometimes the version (for example: HTTP, SSH, FTP, SMTP).

**Solution:** □ Review the detected services and ensure they are necessary.

□ Disable or close unused services and ports.

□ Update and patch services regularly.

□ Use firewalls or access controls to restrict service access to trusted users or networks.

**Bussiness Impact:** This is not a vulnerability, but it shows which services are exposed on the network. Attackers could use this information to identify potential targets for attacks if the services are outdated or misconfigured.

**3)Vulnerability:** Traceroute information

**Severity:** INFO

**Plugin:** 10287

**Description:** Makes a traceroute to the remote host

**Bussiness Impact: 1. Network Infrastructure Disclosure**

Traceroute responses can reveal internal or external network paths, including routers, gateways, and firewall devices. Attackers may use this information to understand the organization's network architecture.

**2. Facilitates Targeted Attacks**

By identifying intermediate devices and network segments, attackers can plan targeted attacks against specific routers, servers, or security devices.

**3. Reconnaissance for Further Exploitation**

Traceroute information helps attackers during the reconnaissance phase of a cyber attack by mapping the network topology and identifying potential weak points.

**4)Vulnerability:** TCP/IP Timestamps Supported

**Severity:** INFO

**Plugin:** 25220

**Description**: The remote host implements TCP timestamps, as defined by RFC1323. A side effect of this feature is that the uptime of the remote host can sometimes be computed.

**Solution:** To reduce information leakage, organizations can disable TCP timestamps if they are not required for network performance.

**Bussiness Impact**: □ Information Disclosure
Attackers may use TCP timestamps to determine the system uptime and gather details about network behavior.

□ System Fingerprinting
The timestamp values can help attackers identify operating systems or network devices, making it easier to plan targeted attacks.

□ Reconnaissance for Further Attacks
Information collected from timestamps may assist attackers during the reconnaissance phase of a cyber attack.

**5)Vulnerability:**Device type

**Severity:** INFO

**Plugin:** 54615

**Description:** The Device Type plugin identifies the type of device running at the scanned IP address. Nessus analyzes network responses and determines whether the device is a server, workstation, router, firewall, printer, or other network device**.**

**Solution**: verify that the detected device type is correct and expected.

Ensure the device is properly secured and updated.

Apply appropriate security configurations based on the device type (e.g., firewall rules, access controls, firmware updates).

**Bussiness Impact:** This is informational only and does not indicate a vulnerability. However, knowing the device type helps security teams understand the network environment and identify which devices may require security controls or monitoring

**6)Vulnerability:** Shor's Harvest Now Decrypt Later

**Severity:** CRITICAL

**Plugin:**298387

**Description:** This plugin reports network services that may be vulnerable now to a future attack by adversaries using a cryptographically relevant quantum computer (CRQC). Shor's is a theoretical algorithm that leverages the unique ability of quantum computation to do massively parallel calculations developed by Peter Shor in 1994.

This algorithm easily computes two classically difficult mathematical problems used in modern cryptography; discrete logarithms, and factoring numbers formed by multiplying large primes. Shor's reduces both of these problems from taking exponential time in chosen cases to being solvable in polynomial time.

**Solution:** Replace affected ciphers with algorithms chosen to resist CRQC attack.

.

**Bussiness Impact: 1. Future Exposure of Sensitive Data**

Sensitive information such as financial records, intellectual property, medical data, or government secrets that are encrypted today may become readable in the future if attackers store the encrypted data and later decrypt it.

**2. Loss of Intellectual Property**

Organizations with long-term valuable data (research, patents, trade secrets) may face significant losses if adversaries decrypt stored communications years later

**7)Vulnerability:** Canonical Ubuntu Linux SEoL (14.04.x)
**Severity:** CRITICAL

**Plugin:** 201408

**Description:** According to its version, Canonical Ubuntu Linux is 14.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

**Solution**: Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

**Bussiness Impact: 1. Increased Security Vulnerabilities**

Since the OS no longer receives security patches, newly discovered vulnerabilities will remain unpatched. Attackers can exploit these weaknesses to compromise the system.

**2. Higher Risk of Cyber Attacks**

Unpatched systems are easier targets for attacks such as malware infections, privilege escalation, and remote exploitation, which could lead to unauthorized access to critical systems.

**3. Data Breach Risk**

Sensitive business data stored or processed on the system may be exposed if attackers exploit known vulnerabilities in the unsupported operating system.

**8)Vulnerability:** Backported Security Patch Detection (WWW)
**Severity:** INFO

**Plugin:** 39521

**Description:** Security patches may have been 'backported' to the remote HTTP server without changing its version number.

Banner-based checks have been disabled to avoid false positives.

Note that this test is informational only and does not denote any security problem.

**Solution:** The theoretical remediation for this issue involves ensuring that the web server software is properly updated and that security patches provided by the operating system vendor are installed. Organizations should regularly update their system packages through the official repositories and verify vendor security advisories to confirm whether the vulnerability has already been patched through backporting.

**Bussiness Impact:**  Unauthorized Access – Attackers may exploit weaknesses in the web server to gain unauthorized access to the system.

 Remote Code Execution – Certain vulnerabilities allow attackers to execute malicious commands on the server.

 Data Breach – Sensitive customer or organizational data stored on the web server could be exposed.

 Service Disruption – Exploits may cause website downtime or denial-of-service conditions, affecting business operations.

**9)Vulnerability: SSH Protocol Versions Supported**
**Severity:**INFO

**Plugin:** 10881

**Description:** This plugin determines the versions of the SSH protocol supported by the remote SSH daemon.

**Solution:**

**Bussiness Impact**: **Unauthorized System Access**
Attackers may exploit weaknesses in SSH version 1 to gain unauthorized access to servers or network devices.

**Data Interception**
Weak encryption algorithms in SSHv1 may allow attackers to intercept or decrypt sensitive information transmitted during remote sessions.

**Man-in-the-Middle Attacks**
The protocol lacks strong integrity protection, making it easier for attackers to perform **Man-in-the-Middle Attack** and manipulate communications between the client and server.

**10)Vulnerability:** Backported Security Patch Detection (SSH
**Severity:** INFO

**Plugin:** 39520

**Description:** Security patches may have been 'backported' to the remote SSH server without changing its version number.

Banner-based checks have been disabled to avoid false positives.

Note that this test is informational only and does not denote any security problem.

**Solution: Backported Security Patch Detection (SSH)** usually appears in vulnerability scanners (like **Nessus**, **OpenVAS**, or **Qualys**) when the scanner cannot confirm whether an **SSH vulnerability** is actually fixed because some Linux distributions **backport security patches without changing the software version number**.

.

**TITLE:**

# Design and apply context-aware access controls based on user identity, device posture, location, and application risk

**Overview:**

- Modern organizations face increasing cybersecurity threats due to remote work, cloud applications, and diverse devices accessing enterprise systems. Traditional security models that rely only on usernames and passwords are no longer sufficient.
- This project focuses on designing and implementing **context-aware access controls**, where access decisions are made dynamically based on multiple contextual factors such as **user identity, device posture, location, and application risk level**.
- The goal of this project is to build a **smart access control framework** that evaluates the context of each access request before granting or denying permission.
- The proposed system uses **identity-based authentication**, device security checks, geographic location verification, and application sensitivity levels to determine the appropriate level of access.

## 1. Concept of Context-Aware Access Control

Context-aware access control is a security approach where access decisions are based on contextual information rather than only static credentials.

The system collects contextual data related to the access request and evaluates it against predefined security policies. Based on the risk level, the system decides whether to:

- Allow access
- Request additional authentication
- Limit user privileges
- Deny access

This approach improves security because it continuously evaluates the risk level of each access request.

Example:
An employee accessing an internal portal from a company laptop in the office network may receive direct access. However, the same employee accessing a financial system from an unknown device in another country may require additional verification.

## 2. Zero Trust Security Model

The project follows the Zero Trust Security Model, which is a modern cybersecurity approach.

The main principle of Zero Trust is:

"Never Trust, Always Verify."

This means that no user or device is trusted automatically, even if they are inside the corporate network. Every access request must be verified before granting permission.

Zero Trust security includes the following principles:

- Continuous authentication and authorization
- Least privilege access
- Device verification
- Risk-based access control
- Continuous monitoring

Context-aware access control systems are a key component of Zero Trust architecture.

## 3. Location-Based Access Control

Location awareness helps the system identify the geographic location or network from which the user is accessing the system.

Location checks include:

- Office network
- Home network
- Public Wi-Fi networks
- Foreign or suspicious countries
- VPN connections

Example:
If a user normally logs in from Chennai but suddenly attempts to log in from another country, the system may require additional authentication.

Location analysis helps detect suspicious login activities.

## 4. Device Posture

Device posture refers to the security condition of the device used to access the system.

The system checks whether the device meets the organization's security standards.

Device posture checks may include:

- Operating system updates
- Antivirus status
- Firewall status
- Device encryption

- Device registration
- Mobile device management compliance

Example:
If a device does not have updated security patches, the system may block access or restrict certain actions.

## 5. User Identity

User identity verification ensures that the person requesting access is a legitimate and authorized user.

Authentication methods include:

- Username and password
- Multi-factor authentication (MFA)
- Biometric authentication
- Single Sign-On (SSO)

Identity systems also manage user roles and permissions.

Example:
An employee working in the finance department may have access to financial applications, while other employees cannot access them.

## 6.Application Risk Level

Different applications have different levels of sensitivity. Some applications contain highly confidential data and require stronger security controls.

Applications can be categorized as:

Low Risk Applications

Examples:

- Internal dashboards
- Employee news portals

These applications usually require basic authentication.

Medium Risk Applications

Examples:

- HR systems
- Document management systems

These applications may require additional verification.

High Risk Applications

Examples:

- Financial management systems
- Customer databases
- Administrative panels

These applications require strong authentication and strict security policies.

## Conclusion

**Stage 1: Assessment and Requirement Analysis**

In this stage, the organization identifies and evaluates the factors required for implementing context-aware access control. This includes analyzing user identities, device security posture, geographic location, and application risk levels. Existing access control mechanisms and security policies are reviewed to understand gaps. The goal is to determine which users should access which resources under specific conditions and to define security requirements for a context-aware system.

**Stage 2:**The Nessus vulnerability scan successfully identified several security findings on the target system, including **informational, medium, high, and critical severity issues**. **Design and Implementation**

In this stage, the organization designs and deploys the context-aware access control framework. Security policies are created based on conditions such as **authenticated user identity, device compliance status, location of access, and sensitivity of the application**. Technologies such as **Multi-Factor Authentication**, device compliance checks, and adaptive authentication are integrated to enforce these policies. The system dynamically evaluates the context before granting or restricting access.

Additionally, the system was found to be running Backported Security Patch Detection (WWW)

By analyzing the results of the Nessus scan and implementing the recommended solutions—such as **upgrading outdated software, disabling weak encryption protocols, and strengthening security configurations**—organizations can significantly reduce their attack surface and improve overall system security. Regular vulnerability scanning and timely remediation are essential for maintaining a **strong cybersecurity posture**

**Stage 3** : The implementation of Zscaler Private Access marks a pivotal shift from a vulnerable, network-centric security model to a resilient, identity-centric Zero Trust architecture. By enforcing least-privilege access and rendering private applications invisible to the internet, this project effectively neutralizes the threats of lateral movement and network-based attacks. The solution not only fortifies the organization's security posture against modern cyber threats but also delivers a seamless and high-performance experience for a distributed workforce. Furthermore, the decoupling of access from the network simplifies IT operations, reduces dependency on legacy VPN infrastructure, and provides granular visibility into user-application interactions. Ultimately, this initiative establishes a future-ready foundation for secure digital transformation..

## Future Scope:

## Stage1:

future scope of web application testing

The future scope of web application testing is promising and evolving rapidly, driven by the continuous growth of the internet and web-based applications.

Here are some key aspects of its future scope:

▪ Increased Demand: As more businesses and services move online, the demand for web applications continues to grow. This, in turn, increases the demand for web application testing to ensure security, reliability, and functionality.

▪ Advanced Technologies: The complexity of web applications is rising with the integration of

advanced technologies like AI, IoT, and blockchain. Testing these cutting-edge applications will require specialized skills and tools.

▪ Security Emphasis: With the growing number of cyber threats and data breaches, security testing for web applications will become even more critical. Testers will need to focus on vulnerabilities, data protection, and compliance with regulations like GDPR.

**Stage2:** To further enhance system security and vulnerability management, the following steps can be considered in the future:

**AI-Driven Testing**: The integration of artificial intelligence (AI) and machine learning (ML) into web application testing tools will revolutionize the way vulnerabilities are identified. AI

algorithms can swiftly scan vast amounts of code and data to pinpoint vulnerabilities that might elude human testers.

**IoT and Mobile App Testing:** With the proliferation of Internet of Things (IoT) devices and the increasing usage of mobile applications, the scope of web application testing will extend to encompass these areas. Ensuring the security of IoT devices and the interfaces they use will become critical.

## Stage3:

Integration with Zscaler Internet Access (ZIA): Converging Private Access (ZPA) with Internet Access (ZIA) to create a unified Secure Access Service Edge (SASE) platform, managing all web and private traffic through a single policy framework.

▪ Advanced Device Posture Checking: Moving beyond basic compliance to incorporate real-time risk scores from EDR tools, blocking access if a device shows signs of active compromise.

▪ Privileged Remote Access: Extending ZPA to third-party vendors and contractors with time-bound, audited access to specific critical systems, replacing jump boxes and bastion hosts.

▪ IoT/OT Segmentation: Applying the same micro-tunneling principles to Internet of Things (IoT) and Operational Technology (OT) devices to ensure they can only communicate with specific management servers.

▪ AI-Driven Anomaly Detection: Leveraging machine learning on ZPA logs to detect behavioral anomalies, such as a user accessing an application at an unusual hour or from a strange location, triggering automated MFA challenges or access revocation.

▪ Cloud Workload Protection: Utilizing ZPA to secure connections between containers and microservices in multi-cloud environments (AWS, Azure, GCP), ensuring east-west traffic between workloads is encrypted and authenticated.

▪ Automated Provisioning/Deprovisioning: Enhancing the identity provider integration to automatically revoke application access the moment an employee is terminated or changes roles, ensuring near real-time access control.

## **Topics Explored**:

OWASP 10 , Scanning ,Vulnerability, Awareness, Concept of Context-Aware Access Control, Zero Trust Security Model, User Identity, Device Posture, Location-Based Access Control, Application Risk Level.

## **Tools Explored:**

Zscaler, Nessus, OWASP 10.